

VULNERABILITY ASSESSMENT

List Of Identified Vulnerability

Metasploitable 2 Lab Environment

(192.168.1.3 & 192.168.122.4)

Critical Severity Vulnerabilities (CVSS 9.0 - 10.0)

- **vsftpd Compromised Source Packages Backdoor**

CVE ID: CVE-2011-2523

Affected Asset: 192.168.1.3 (Port 21 / TCP)

Description: The remote FTP server is running a version of vsftpd (2.3.4) that contains a malicious backdoor within its source code.

Impact Analysis: An attacker can trigger this backdoor by appending a smiley face to the FTP username, which secretly opens a listening shell on port 6200. This grants the attacker immediate, unauthenticated root-level access to the server, allowing total system compromise of the Ghana Maritime Defense Command (GMDC) asset.

- **UnrealIRCd Backdoor Detection**

CVE ID: CVE-2010-2075

Affected Asset: 192.168.122.4 (Port 6667 / TCP)

Description: The remote IRC server is running a version of UnrealIRCd that was distributed with a Trojan backdoor.

Impact Analysis: This vulnerability allows an unauthenticated, remote attacker to execute arbitrary system commands. Because the IRC daemon is executing as root (uid=0), exploiting this flaw grants the attacker complete administrative control over the host.

- **Apache Tomcat AJP Remote Code Execution (Ghostcat)**

CVE ID: CVE-2020-1938

Affected Asset: 192.168.1.3 (Port 8009 / TCP)

Description: The Apache Tomcat instance is vulnerable to an arbitrary file read and inclusion flaw via the AJP connector.

Impact Analysis: An attacker can exploit this to read sensitive web application files (such as /WEB-INF/web.xml) or source code. If the application allows file uploads, this can be chained to achieve full Remote Code Execution (RCE) on the web server, establishing a foothold for internal network pivoting.

- **Database Default Credentials (MySQL & PostgreSQL)**

CVE ID: Multiple/Configuration Flaw

Affected Asset: 192.168.1.3 (Ports 3306 & 5432 / TCP)

Description: The MySQL and PostgreSQL database services are configured with factory default or blank credentials (e.g., MySQL root with an empty password, and PostgreSQL postgres:postgres).

Impact Analysis: Attackers can remotely log into the core databases without requiring any exploits. This represents a catastrophic failure of data confidentiality and integrity, allowing adversaries to steal, manipulate, or delete GMDC maritime records.

- **Operating System (OS) End of Life (EOL)**

CVE ID: N/A (Structural Flaw)

Affected Asset: 192.168.122.4 & 192.168.1.3

Description: The target systems are running Canonical Ubuntu Linux version 8.04. This operating system reached its Security End of Life on May 9, 2013.

Impact Analysis: The vendor no longer provides security patches for these systems. Any vulnerabilities discovered in the Linux kernel or default packages over the past

13 years remain unpatched, making the system structurally indefensible against modern exploitation frameworks.

High Severity Vulnerabilities (CVSS 7.0 - 8.9)

- **Samba Badlock Vulnerability**

CVE ID: CVE-2016-2118

Affected Asset: 192.168.122.4 (Port 445 / TCP)

Description: The SMB service running on the host is vulnerable to Badlock, a flaw in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols.

Impact Analysis: A Man-in-the-Middle (MitM) attacker can force a downgrade of the authentication level over RPC channels. This allows the attacker to execute arbitrary Samba network calls in the context of the intercepted user, enabling them to view or modify sensitive security data within the network.

- **Unencrypted Cleartext Logins (r-services)**

CVE ID: CVE-1999-0651

Affected Asset: 192.168.1.3 (Ports 512, 513, 514 / TCP)

Description: The server is running legacy rexec, rlogin, and rsh services.

Impact Analysis: These services transmit all session data—including usernames and passwords—in cleartext.

Furthermore, rlogin is configured to allow root access without a password. Any attacker capable of sniffing network traffic can capture administrative credentials, or log in directly without authentication.

- **Java RMI Server Insecure Default Configuration**

CVE ID: CVE-2011-3556

Affected Asset: 192.168.1.3 (Port 1099 / TCP)

Description: The Remote Method Invocation (RMI) server contains an insecure default configuration allowing remote class loading.

Impact Analysis: An unauthenticated, remote attacker can transmit crafted packets to execute arbitrary code on the system with elevated privileges.

Medium & Low Severity Vulnerabilities (Chained Risks)

- **SSL/TLS & Cryptographic Weaknesses**

Description: Both servers support anonymous cipher suites, weak MAC algorithms, and deprecated protocols (SSLv2/SSLv3).

Impact Analysis: While typically requiring an attacker to already be positioned on the local network (MitM), these flaws allow for the decryption or manipulation of supposedly secure administrative traffic.

- **Web Directory Indexing & Information Disclosure**

Description: The web server on 192.168.1.3 has directory indexing enabled (e.g., /icons/, /doc/) and exposes phpinfo() outputs.

Impact Analysis: These misconfigurations provide attackers with a detailed blueprint of the web server's architecture, revealing exact software versions, physical file paths, and internal configuration variables, which accelerates the discovery of viable exploit chains.